UGH Cybersecurity Playbook

Threat, Risk & Control Assessment

Adeola Oguntuga

Prepared for SM6375 – Cyber Operations Capstone, University of Houston–Downtown, Spring 2026

Portfolio edition, revised November 2026

UGH is a fictional organization used as the capstone case study. All names, systems and figures describe that scenario.

1. Executive Summary

This playbook assesses eight threats to UGH, a 1,900-employee IT services provider operating across North America. Each threat is mapped to MITRE ATT&CK, scored on a 5×5 likelihood and impact matrix, and paired with policy, tool and training controls traceable to NIST SP 800-53 Rev. 5 and the NIST Cybersecurity Framework (CSF) 2.0.

Current risk profile: two threats are rated Critical (credential phishing and unpatched or end-of-life servers), four are High and two are Medium. With the recommended controls in place, every threat drops to Medium or Low.

Priority actions

- **Migrate the three Windows Server 2016 systems before January 12, 2027,** when Microsoft extended support ends, or approve a time-bound ESU exception. This is the only time-bound item in the playbook. (T5)
- **Enforce phishing-resistant MFA through Conditional Access** for all users, with FIDO2 keys for administrators. This one control reduces risk for T1, T3 and T4.
- **Replace security-question verification at the Help Desk** with callback verification and Temporary Access Passes. (T1)
- **Deploy USB device control, Purview sensitivity labels and DLP** to close the two main data exfiltration paths. (T2, T3)
- **Retire the unsupported Cisco ASA 5520** and introduce quarterly firewall rule recertification. (T6)

Most of these controls use Microsoft 365 E5 features UGH already licenses (Entra ID Protection, Defender for Identity, Defender for Cloud Apps, Intune, Purview DLP and Insider Risk Management), so the main investment is configuration and process rather than new tooling. The full risk register is in Section 6.

2. Scope & Methodology

The playbook follows the NIST CSF 2.0 functions. Section 3 covers **Identify** (assets, applications and owners), Section 4 covers **Protect** and **Detect** for each threat, and Section 5 covers **Respond** and **Recover**. **Govern** runs throughout as named risk owners, policies and the risk register in Section 6.

- **Threat modeling:** MITRE ATT&CK Enterprise tactics and techniques.
- **Control mapping:** NIST SP 800-53 Rev. 5 control identifiers and CSF 2.0 subcategories.
- **Current risk** reflects UGH's environment as described in Section 3, with existing controls. **Residual risk** is the expected rating once the recommended controls are in place.

Risk scoring

Risk score = Likelihood × Impact, each rated 1–5.

Score	Likelihood	Impact
1	**Rare:** not expected within 5 years	**Negligible:** no meaningful data or service impact
2	**Unlikely:** could occur within 5 years	**Minor:** limited, contained exposure or brief disruption to one team

Score	Likelihood	Impact
3	**Possible:** could occur within 1–2 years	**Moderate:** internal data exposed or one business application down for up to a day
4	**Likely:** expected within the year	**Major:** sensitive data exposed or several applications compromised
5	**Almost certain:** expected several times a year	**Severe:** regulated data breach, domain-wide compromise or extended outage

Likelihood ↓ / Impact →	1	2	3	4	5
5	5	10	15	20 **T4**	25
4	4	8 **T8**	12	16	20 **T5**
3	3	6	9	12 **T1, T3**	15 **T2, T6**
2	2	4	6	8	10 **T7**
1	1	2	3	4	5

Bands: **Low** 1–5 · **Medium** 6–10 · **High** 11–15 · **Critical** 16–25. Threat IDs show where each threat currently sits.

3. Identify: UGH Environment

Company Overview

UGH is a mid-size IT services provider with about 1,900 employees across multiple North American locations. Core business functions include human resources, financial operations, and travel and expense management, supported by cross-department collaboration tools. The IT department includes an IT Help Desk, Desktop Support, an Application Development team, a Cloud team and an IT Security team. It is led by the Chief Information Officer, who has final approval authority over technology acquisitions and production deployments.

Hardware & Infrastructure Assets

Asset	Description	Security notes
Workstations	HP EliteBook 845 G11 (14-inch) laptops running Windows 11, issued to all employees	BitLocker full disk encryption enforced; recovery keys stored on a dedicated BitLocker key management server
Servers	On-premises Windows Server 2016 (three systems) and 2019, hosting AD domain controllers, the BitLocker key management server and data center workloads	Data at rest encrypted. Windows Server 2016 extended support ends January 12, 2027

Asset	Description	Security notes
Network	Routers, switches, Cisco Secure Firewall 3130 and Cisco ASA 5520	Two firewall platforms with overlapping rulesets; the ASA 5520 is past vendor support
Cloud	Microsoft 365 E5 tenant (Entra ID, Exchange Online, SharePoint, OneDrive, Teams)	Connects on-premises infrastructure to Microsoft cloud services
Mobile devices	Company-issued phones and tablets	Managed through Microsoft Intune (MDM), included in Microsoft 365 E5

Application Assets

All applications must be approved by the Change Advisory Board (CAB), chaired by the CIO. All 12 enterprise applications use Microsoft single sign-on, with access granted through Active Directory security groups.

Application	Function	Data classification	Notes
Microsoft 365 E5	Productivity, email, collaboration and security platform (Office apps, Exchange, Teams, OneDrive, SharePoint, Defender, Entra ID, Intune, Purview, Power BI Pro)	Internal / Confidential	Licensed through December 2026; renewal required
Workday	Human resources: payroll, benefits, personnel records	Restricted (employee PII)	Microsoft SSO
Concur	Travel booking and expense management	Confidential (financial, limited PII)	Microsoft SSO
UGH Financial Operations (UFO)	In-house finance and accounting application built by Application Development	Restricted (financial)	Source in a managed code repository; changes follow a strict change process
Other enterprise applications (7)	Additional business applications	Varies	Microsoft SSO; to be added to the asset inventory

Security & Management Tooling

Tool	Purpose
Microsoft Defender XDR (Endpoint, Office 365, Identity, Cloud Apps)	Endpoint protection, email security, identity threat detection and cloud app control
Microsoft Entra ID (P2)	Identity, SSO, MFA, Conditional Access and Identity Protection
Microsoft Purview	Sensitivity labels, DLP, Insider Risk Management and audit logging
Microsoft Intune	Device compliance, configuration, remote lock and wipe

Tool	Purpose
Qualys	Vulnerability scanning (currently on a weekly rotation)
SolarWinds	IT asset inventory, network monitoring and configuration management

Roles & Risk Ownership

Name	Title	Security responsibilities
Mr. Roberts	Chief Information Officer	Chairs the CAB; final approval for technology and production changes; accepts residual risk
Ingrid	IT Security Manager	Owns security policies, the risk register and incident response
Eric	Cloud Manager	Microsoft 365, Entra ID and SharePoint configuration and cloud controls
Gina	Application Development Director	Secure development and change management for UFO
IT Help Desk	Virtual technical support	Identity verification for resets; first point of incident reporting
IT Desktop Support	In-person technical support	Endpoint deployment, device recovery and replacement
IT Security Team	Security operations	Monitoring, vulnerability scanning, alert triage and response

4. Protect & Detect: Threat Analysis

Threats 1–4 target UGH's data and identities, and Threats 5–8 target its hardware and infrastructure. Each threat includes a scenario, risk scoring, an ATT&CK mapping, recommended policy, tool and training controls with framework references, and detection guidance.

Threat 1: Help Desk Social Engineering (Vishing)

An attacker calls the published IT Help Desk number, impersonates an employee using details gathered from LinkedIn or earlier breaches, and asks for a password reset or MFA re-registration. If the agent complies, the attacker registers their own authenticator and signs in to Microsoft 365 and every SSO-connected application.

Assets affected	Threat actor	Current risk	Residual risk	Risk owner
Entra ID user accounts; all 12 SSO-integrated applications	External attacker	**12 – High**	**6 – Medium**	Ingrid, IT Security Manager (with Help Desk lead)

Risk assessment

- **Likelihood: 3 (Possible).** The Help Desk number is public, and help desk impersonation is a well-documented technique (CISA advisory AA23-320A). Verification currently relies on security questions, whose answers are often discoverable.
- **Impact: 4 (Major).** A reset account grants access to email, Workday, Concur, UFO and every other SSO application. Impact rises further if the target holds privileged access.
- **Current risk: 12 (High).** Residual after recommended controls: 2 × 3 = 6 (Medium). Callback verification and phishing-resistant MFA make a phone-based takeover much harder and limit what a single reset can unlock.

MITRE ATT&CK mapping

Tactic	Technique	How it applies
Initial Access (TA0001)	T1566.004 Phishing: Spearphishing Voice	Attacker uses a phone call to the Help Desk to gain access.
Defense Evasion (TA0005)	T1656 Impersonation	Attacker poses as a legitimate employee to the agent.
Persistence (TA0003)	T1098.005 Account Manipulation: Device Registration	Attacker registers their own MFA device after the reset.
Initial Access (TA0001)	T1078.004 Valid Accounts: Cloud Accounts	Attacker signs in to Entra ID with the reset credentials.

Recommended controls

Type	Control	NIST 800-53	CSF 2.0
Policy	**Help Desk Identity Verification Standard.** Replace security questions with a callback to the phone number on record in Workday. Require manager confirmation for MFA resets and for all privileged accounts. Issue a time-limited Entra ID Temporary Access Pass instead of reading a password over the phone, and notify the user through a second channel after any reset.	IA-12, IA-5, AC-2	PR.AA-01, PR.AA-02
Tool	Enforce phishing-resistant MFA through Entra ID Conditional Access (Microsoft Authenticator with number matching; FIDO2 keys for administrators). Enable Self-Service Password Reset so most resets never reach an agent, and make MFA enrollment part of onboarding.	IA-2(1), IA-2(2), IA-2(8)	PR.AA-03
Training	Annual social-engineering training for Help Desk staff, plus quarterly simulated vishing calls run by IT Security, with results reported to the IT Security Manager.	AT-2(3), AT-3	PR.AT-02

Detection

- Entra ID audit logs: an admin-initiated password reset followed shortly by a new MFA method registration.
- Entra ID Protection: unfamiliar sign-in properties or impossible travel right after a reset.
- Help Desk ticket review: resets with no recorded verification step.

Threat 2: Insider Data Exfiltration from Workday

An HR employee with privileged Workday access exports sensitive employee data (payroll, benefits and personnel records) to their laptop, then copies it to a personal USB drive. The actor may be a disgruntled employee or someone recruited by a competitor.

Assets affected	Threat actor	Current risk	Residual risk	Risk owner
Workday; employee PII; company laptops	Malicious insider	**15 – High**	**8 – Medium**	Ingrid, IT Security Manager (with HR leadership)

Risk assessment

- **Likelihood: 3 (Possible).** The employee already has legitimate access, and USB storage is currently allowed on company laptops.
- **Impact: 5 (Severe).** Workday holds employee PII and payroll data. A breach would trigger state breach-notification obligations, regulatory exposure and reputational harm.
- **Current risk: 15 (High).** Residual after recommended controls: 2 × 4 = 8 (Medium). Device control and DLP remove the easiest exfiltration path and make bulk exports visible. A trusted insider can never be fully prevented, so impact remains significant.

MITRE ATT&CK mapping

Tactic	Technique	How it applies
Collection (TA0009)	T1213 Data from Information Repositories	Insider exports records from Workday.
Collection (TA0009)	T1074.001 Data Staged: Local Data Staging	The export is staged on the laptop before transfer.
Exfiltration (TA0010)	T1052.001 Exfiltration Over Physical Medium: Exfiltration over USB	Data is copied to a personal USB drive.

Recommended controls

Type	Control	NIST 800-53	CSF 2.0
Policy	Grant Workday roles on least privilege by job function, with separation of duties for bulk-export rights. Run quarterly access reviews of all Workday security groups, certified by HR leadership. Prohibit personal removable media in the Acceptable Use Policy.	AC-2, AC-5, AC-6, MP-7	PR.AA-05
Tool	Block USB mass storage through Intune and Defender for Endpoint device control, allowing keyboards, mice, webcams and approved encrypted drives. Apply Purview DLP and Insider Risk Management policies to detect bulk Workday exports and sensitive data copied to removable media.	MP-7, SI-4, PM-12	PR.DS-01, DE.CM-03
Training	Annual insider-threat awareness and Acceptable Use training. Train managers on behavioral warning signs and how to report concerns.	AT-2(2)	PR.AT-01

Detection

- Defender for Endpoint device-control events showing USB storage blocked or allowed.
- Purview Insider Risk alerts for data-theft indicators, weighted for departing employees through the HR connector.
- Workday audit reports showing large report exports or exports outside business hours.

Threat 3: Credential Abuse: SharePoint Data Theft

An employee with valid credentials to the IT SharePoint site downloads confidential internal IT documentation, such as network diagrams, configurations and runbooks, and uploads it to a personal cloud storage account to sell on dark-web forums. An external attacker using stolen credentials could do the same.

Assets affected	Threat actor	Current risk	Residual risk	Risk owner
SharePoint Online; internal IT documentation	Malicious insider or account takeover	**12 – High**	**6 – Medium**	Eric, Cloud Manager

Risk assessment

- **Likelihood: 3 (Possible).** The employee has front-end and back-end access to the site, and there is currently no data classification or download monitoring.
- **Impact: 4 (Major).** IT documentation gives an attacker a blueprint of the network, servers and security controls, making a later breach far easier.
- **Current risk: 12 (High).** Residual after recommended controls: 2 × 3 = 6 (Medium). Labels, download restrictions and cloud-app controls block the most likely exfiltration paths and narrow who can see the documents.

MITRE ATT&CK mapping

Tactic	Technique	How it applies
Initial Access (TA0001)	T1078 Valid Accounts	Uses legitimate credentials, so the activity looks normal.
Collection (TA0009)	T1213.002 Data from Information Repositories: SharePoint	Mines IT documentation from SharePoint.
Exfiltration (TA0010)	T1567.002 Exfiltration Over Web Service: Exfiltration to Cloud Storage	Uploads the files to a personal cloud storage service.

Recommended controls

Type	Control	NIST 800-53	CSF 2.0
Policy	**Data Classification Policy** (Public, Internal, Confidential, Restricted) with IT architecture documents labeled Confidential at minimum. Restrict the IT SharePoint site to IT staff on a need-to-know basis, with site permissions reviewed every six months.	RA-2, AC-3, AC-6	ID.AM-05, PR.AA-05
Tool	Use Purview sensitivity labels with DLP rules that block downloads to unmanaged devices and alert on bulk downloads. Use Defender for Cloud Apps to block uploads to unsanctioned personal cloud storage. Monitor Purview Audit FileDownloaded and FileSyncDownloadedFull events.	AC-4, SI-4, AU-6	PR.DS-01, DE.CM-03
Training	Annual training on data classification, handling and approved storage locations.	AT-2	PR.AT-01

Detection

- Purview Audit and Defender for Cloud Apps: one user mass-downloading from SharePoint.
- Defender for Cloud Apps: uploads to unsanctioned cloud storage apps.
- Conditional Access logs: SharePoint access from unmanaged devices.

Threat 4: Credential Phishing (Spearphishing Link)

An external attacker sends a convincing fake Microsoft 365 "password expiring" email that links to a look-alike sign-in page. Modern adversary-in-the-middle (AiTM) phishing kits proxy the real Microsoft login page. They capture both the password and the session cookie, which lets the attacker get past standard MFA.

Assets affected	Threat actor	Current risk	Residual risk	Risk owner
Microsoft 365 accounts; SSO-connected applications	External, financially motivated attacker	**20 – Critical**	**9 – Medium**	Ingrid, IT Security Manager

Risk assessment

- **Likelihood: 5 (Almost certain).** Phishing remains the most common initial access vector. Every employee receives email daily, and Microsoft 365 tenants are a primary target.
- **Impact: 4 (Major).** A compromised account exposes email, OneDrive, SharePoint and all SSO applications, and can be used for business email compromise or internal phishing.
- **Current risk: 20 (Critical).** Residual after recommended controls: 3 × 3 = 9 (Medium). Phishing will keep arriving, but filtering, phishing-resistant MFA and token protection stop most captured credentials from being usable.

MITRE ATT&CK mapping

Tactic	Technique	How it applies
Initial Access (TA0001)	T1566.002 Phishing: Spearphishing Link	Malicious link to a fake Microsoft 365 sign-in page.
Credential Access (TA0006)	T1557 Adversary-in-the-Middle	The AiTM kit proxies the real login and captures credentials.
Credential Access (TA0006)	T1539 Steal Web Session Cookie	The captured session token is replayed to get past MFA.
Initial Access (TA0001)	T1078.004 Valid Accounts: Cloud Accounts	Attacker signs in as the victim.

Recommended controls

Type	Control	NIST 800-53	CSF 2.0
Policy	A suspicious-email reporting procedure (Report button in Outlook) with IT Security triage within 4 business hours. An email authentication standard requiring SPF, DKIM and DMARC at p=reject for all UGH domains.	IR-6, SI-8	DE.AE-02, RS.MA-01
Tool	Defender for Office 365 Safe Links, Safe Attachments and impersonation protection. Conditional Access requiring compliant devices and phishing-resistant MFA, with token protection to limit replay of stolen cookies.	SI-3, SI-8, IA-2(8)	PR.AA-03, DE.CM-09

Type	Control	NIST 800-53	CSF 2.0
Training	Monthly phishing simulations through Defender Attack Simulation Training, with just-in-time training for users who click and annual security awareness training for all employees.	AT-2(1)	PR.AT-01

Detection

- Defender for Office 365: user-reported messages and campaign views.
- Entra ID Protection: anomalous token, AiTM and unfamiliar-location sign-in detections.
- Exchange audit: new inbox rules that forward or delete mail (a common business email compromise follow-up).

Threat 5: Exploitation of Unpatched or End-of-Life Windows Servers

An attacker with a foothold on the internal network exploits a known vulnerability on one of UGH's Windows Server 2016 or 2019 systems before the patch is applied, then escalates privileges to reach Active Directory. UGH's three Windows Server 2016 systems reach the end of extended support on **January 12, 2027**. After that date Microsoft releases no further security updates unless the organization buys Extended Security Updates (ESU).

Assets affected	Threat actor	Current risk	Residual risk	Risk owner
Windows Server 2016/2019; AD domain controllers; BitLocker key management server	External attacker or ransomware operator after initial access	**20 – Critical**	**8 – Medium**	Mr. Roberts, CIO (accountable); IT Security Team (responsible)

Risk assessment

- **Likelihood: 4 (Likely).** A weekly scan rotation and a 72-hour critical patching SLA leave exposure windows, and the 2016 servers will stop receiving patches entirely in January 2027.
- **Impact: 5 (Severe).** Compromise of a domain controller gives domain-wide control, including access to the BitLocker recovery keys.
- **Current risk: 20 (Critical).** Residual after recommended controls: 2 × 4 = 8 (Medium). Migrating off Windows Server 2016 and moving to continuous scanning closes the largest exposure. Domain controllers remain high-value targets.

MITRE ATT&CK mapping

Tactic	Technique	How it applies
Lateral Movement (TA0008)	T1210 Exploitation of Remote Services	Attacker exploits an unpatched service on an internal server.
Privilege Escalation (TA0004)	T1068 Exploitation for Privilege Escalation	A local exploit gives SYSTEM or administrator rights.
Credential Access (TA0006)	T1003.006 OS Credential Dumping: DCSync	With domain privileges, the attacker replicates password hashes from AD.

Recommended controls

Type	Control	NIST 800-53	CSF 2.0
Policy	Approve a plan to migrate the three Windows Server 2016 systems to a supported version before January 12, 2027. If that isn't possible, buy ESU as a documented, time-bound risk exception approved by the CIO. Tighten the critical patching SLA to 24 hours for Tier 0 systems (domain controllers and key management).	SA-22, SI-2, CM-8	ID.AM-02, PR.PS-02
Tool	Move Tier 0 servers to continuous, agent-based Qualys scanning, tag Windows Server 2016 assets as high priority and auto-escalate critical findings to IT Security. Deploy Defender for Identity on domain controllers.	RA-5, SI-4	ID.RA-01, DE.CM-09
Training	A quarterly vulnerability and patch management review with system administrators, covering SLA metrics and open exceptions.	AT-3	PR.AT-02

Detection

- Qualys: critical findings that are past their SLA.
- Defender for Identity: DCSync, suspicious replication and privilege-escalation alerts.
- Domain controller security events 4672, 4720 and 4728 (special privileges, account creation, privileged group changes).

Threat 6: Firewall Misconfiguration or Rule Exploitation

An attacker finds an overly permissive or outdated rule on UGH's Cisco Secure Firewall 3130 or Cisco ASA 5520 that allows traffic into the restricted server subnet. The ASA 5520 is a legacy appliance that has been past Cisco's end-of-support date for several years, so it no longer receives security fixes.

Assets affected	Threat actor	Current risk	Residual risk	Risk owner
Firewalls; server subnet (domain controllers, BitLocker key server, critical applications)	External attacker; insider with firewall admin access	**15 – High**	**8 – Medium**	Ingrid, IT Security Manager (with the network team)

Risk assessment

- **Likelihood: 3 (Possible).** Running two firewall platforms with overlapping rulesets makes drift and misconfiguration likely, and there is no rule-review cadence today.
- **Impact: 5 (Severe).** Exposing the server subnet puts the domain controllers and the BitLocker key server within reach.
- **Current risk: 15 (High).** Residual after recommended controls: 2 × 4 = 8 (Medium). Default-deny rules, regular recertification and a single supported platform sharply reduce the chance of an exploitable gap.

MITRE ATT&CK mapping

Tactic	Technique	How it applies
Discovery (TA0007)	T1046 Network Service Discovery	Scanning reveals services reachable through a permissive rule.
Defense Evasion (TA0005)	T1599 Network Boundary Bridging	Attacker passes traffic across the segmentation boundary, or changes rules if they gain firewall admin access.
Lateral Movement (TA0008)	T1021 Remote Services	Attacker uses RDP or SMB to reach servers through the opened path.

Recommended controls

Type	Control	NIST 800-53	CSF 2.0
Policy	**Firewall Rule Standard:** default-deny, a named business owner and an expiry date for every rule, quarterly rule recertification and all changes through the CAB. Plan to retire the ASA 5520 and consolidate onto the supported Secure Firewall 3130.	CM-3, CM-6, SC-7, SA-22	PR.PS-01, PR.IR-01
Tool	Use SolarWinds Network Configuration Manager to baseline firewall configurations and alert IT Security on unauthorized changes. Forward firewall logs to the central SIEM.	CM-2, AU-6, SI-4	DE.CM-01
Training	Semi-annual hands-on secure configuration training for the network team on both Cisco platforms.	AT-3	PR.AT-02

Detection

- SolarWinds configuration-change alerts for changes made outside an approved CAB window.
- Firewall logs: allowed traffic from user VLANs to the server subnet on admin ports (RDP, SMB, LDAP).
- Quarterly rule hit-count analysis to find unused or overly broad rules.

Threat 7: Compromise of the SolarWinds Management Platform

An attacker compromises the SolarWinds platform, either through a malicious vendor update (as in the 2020 SUNBURST supply-chain attack) or by exploiting the server directly. SolarWinds holds an inventory of, and credentials for, UGH's servers, laptops and network devices, so controlling it gives broad visibility and administrative reach.

Assets affected	Threat actor	Current risk	Residual risk	Risk owner
SolarWinds server; stored device credentials; all managed assets	Advanced or nation-state attacker	**10 – Medium**	**5 – Low**	Ingrid, IT Security Manager

Risk assessment

- **Likelihood: 2 (Unlikely).** This requires a vendor supply-chain compromise or an existing internal foothold. It is uncommon, but it has happened.
- **Impact: 5 (Severe).** The platform holds credentials and network-wide visibility, so compromising it could lead to control of the whole environment.
- **Current risk: 10 (Medium).** Residual after recommended controls: 1 × 5 = 5 (Low). Isolation, egress restrictions and staged updates make a compromise much less likely, but impact stays severe because of what the platform holds.

MITRE ATT&CK mapping

Tactic	Technique	How it applies
Initial Access (TA0001)	T1195.002 Supply Chain Compromise: Compromise Software Supply Chain	A trojanized vendor update is installed on the platform.
Command and Control (TA0011)	T1071.001 Application Layer Protocol: Web Protocols	Malware beacons over HTTPS to blend in with normal traffic.
Credential Access (TA0006)	T1555 Credentials from Password Stores	Attacker harvests stored device and service credentials from the platform.

Recommended controls

Type	Control	NIST 800-53	CSF 2.0
Policy	Run a supplier risk review for SolarWinds and other privileged tools, and subscribe to vendor security advisories. Validate updates in a test environment before production. Limit platform administration to named individuals, reviewed quarterly.	SR-3, SR-6, SI-7, AC-6(5)	GV.SC-07, ID.RA-08
Tool	Isolate the SolarWinds server in a dedicated management subnet with outbound traffic restricted to approved destinations. Use least-privilege, vaulted service accounts. Monitor with Defender for Endpoint and network egress logging.	SC-7, AC-6, SI-4	PR.IR-01, DE.CM-01
Training	Annual training for platform administrators, including a tabletop exercise on a compromised management tool.	AT-3, IR-3	PR.AT-02

Detection

- Unexpected outbound connections from the SolarWinds server.
- New or modified SolarWinds service accounts or credential entries.
- Defender for Endpoint alerts on the SolarWinds server.

Threat 8: Theft or Loss of Company Laptops

A company laptop is stolen or lost, and whoever has it tries to get at locally stored files, cached email and cached credentials. ATT&CK's Enterprise matrix does not model physical theft itself, so the mapping below covers what an attacker would do next.

Assets affected	Threat actor	Current risk	Residual risk	Risk owner
HP EliteBook laptops; local data; cached credentials	Opportunistic thief or targeted attacker	**8 – Medium**	**6 – Medium**	IT Desktop Support (with IT Security)

Risk assessment

- **Likelihood: 4 (Likely).** Laptop loss and theft are among the most frequent physical security incidents, especially for a workforce spread across multiple sites.
- **Impact: 2 (Minor).** BitLocker full disk encryption is already enforced, which keeps impact low. The remaining exposure is cached credentials on an unlocked or sleeping device and any data not yet synced to OneDrive.
- **Current risk: 8 (Medium).** Residual after recommended controls: 3 × 2 = 6 (Medium). Fast reporting, remote wipe and pre-boot authentication shrink the remaining exposure. Theft itself cannot be eliminated.

MITRE ATT&CK mapping

Tactic	Technique	How it applies
Credential Access (TA0006)	T1003 OS Credential Dumping	Attacker tries to pull cached credentials from the device (for example with Mimikatz).
Credential Access (TA0006)	T1552.001 Unsecured Credentials: Credentials In Files	Attacker searches local files for stored passwords.

Recommended controls

Type	Control	NIST 800-53	CSF 2.0
Policy	**Lost or Stolen Device Policy:** report to the Help Desk within 4 hours. The Help Desk then revokes sessions, resets credentials and starts a remote wipe.	IR-6, AC-19	RS.MA-01
Tool	Keep BitLocker enforced through Intune compliance policy and add pre-boot PIN authentication (TPM + PIN). Enable Intune remote lock and wipe, block non-compliant devices with Conditional Access, and limit cached logons.	SC-28, AC-19(5)	PR.DS-01
Training	Device-handling training: never leave laptops unattended, use cable locks in shared spaces and report losses immediately.	AT-2	PR.AT-01

Detection

- Intune: devices that stop checking in or fall out of compliance.
- Entra ID: sign-ins from the device after it was reported lost.

5. Respond & Recover

The eight threats fall into four incident types. The steps below follow the NIST SP 800-61 Rev. 3 incident response lifecycle. The IT Security Manager leads response, and the CIO is informed of every High or Critical incident.

Incident type	Triggers	Contain	Eradicate & recover	Escalate & notify
Account compromise (T1, T4)	Entra ID Protection alert; user report; suspicious reset	Revoke sessions, disable the account, reset the password and remove unknown MFA methods	Review inbox rules, OAuth app consents and SSO app activity; restore access after verified identity proofing	IT Security Manager; CIO if privileged or data was accessed
Data exfiltration (T2, T3)	DLP or Insider Risk alert; mass-download alert	Suspend access; preserve evidence (legal hold, device image); coordinate with HR and Legal	Scope the data involved, revoke sharing links and tighten permissions	HR, Legal and CIO; breach-notification assessment if PII is involved
Infrastructure compromise (T5, T6, T7)	Defender for Identity alert; unauthorized config change; anomalous egress	Isolate affected hosts, block firewall paths, disable affected service accounts and rotate credentials (reset krbtgt twice if a DC is compromised)	Rebuild from known-good images, restore from backup and validate firewall config against the baseline	CIO; engage an external incident response firm if the domain is compromised
Lost or stolen device (T8)	User report to the Help Desk	Remote lock or wipe through Intune; revoke sessions; reset the password	Confirm BitLocker status at the time of loss; issue a replacement device	IT Security; Legal if the device was unencrypted

Post-incident review: within 10 business days of a High or Critical incident, the IT Security Manager holds a lessons-learned review. Findings update the risk register, control owners and this playbook (CSF 2.0 ID.IM-03, RC.RP-01).

6. Risk Register

All eight risks are treated by **mitigation**. For T5, purchasing ESU is an acceptable fallback only as a documented, time-bound exception approved by the CIO. The register is reviewed quarterly by the IT Security Manager, and residual risks are formally accepted by the CIO.

ID	Threat	Current	Priority controls	Owner	Residual
T1	Help Desk Social Engineering (Vishing)	**12 – High**	Callback verification; phishing-resistant MFA; SSPR	Ingrid, IT Security Manager	**6 – Medium**
T2	Insider Data Exfiltration from Workday	**15 – High**	Least-privilege Workday roles; USB device control; Purview DLP and Insider Risk	Ingrid, IT Security Manager	**8 – Medium**
T3	Credential Abuse: SharePoint Data Theft	**12 – High**	Data classification and labels; DLP; block personal cloud uploads	Eric, Cloud Manager	**6 – Medium**
T4	Credential Phishing (Spearphishing Link)	**20 – Critical**	DMARC p=reject; Defender for Office 365; Conditional Access with token protection	Ingrid, IT Security Manager	**9 – Medium**
T5	Exploitation of Unpatched or End-of-Life Windows Servers	**20 – Critical**	Migrate off Server 2016 by Jan 12, 2027; continuous scanning; Defender for Identity	Mr. Roberts, CIO	**8 – Medium**
T6	Firewall Misconfiguration or Rule Exploitation	**15 – High**	Rule standard and quarterly recertification; retire ASA 5520; config monitoring	Ingrid, IT Security Manager	**8 – Medium**
T7	Compromise of the SolarWinds Management Platform	**10 – Medium**	Supplier review; staged updates; isolated subnet with egress control	Ingrid, IT Security Manager	**5 – Low**
T8	Theft or Loss of Company Laptops	**8 – Medium**	BitLocker + PIN; 4-hour reporting; Intune remote wipe	IT Desktop Support	**6 – Medium**

Appendix: References

- NIST. The NIST Cybersecurity Framework (CSF) 2.0. NIST CSWP 29, February 2024.
- NIST. SP 800-53 Rev. 5, Security and Privacy Controls for Information Systems and Organizations.
- NIST. SP 800-61 Rev. 3, Incident Response Recommendations and Considerations for Cybersecurity Risk Management, April 2025.
- NIST. SP 800-63B, Digital Identity Guidelines: Authentication and Authenticator Management.
- MITRE. ATT&CK Enterprise Matrix. attack.mitre.org.
- CISA. Advisory AA23-320A, Scattered Spider, November 2023.
- Microsoft. Windows Server 2016 product lifecycle (extended support ends January 12, 2027).